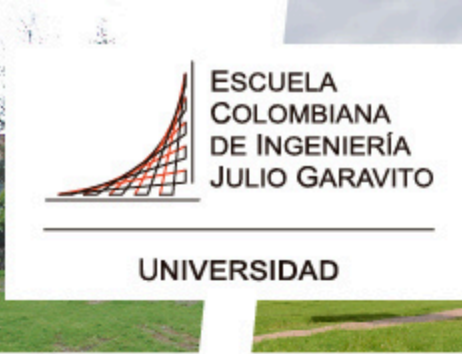


Autenticación, autorización y accounting (AAA)

Fundamentos de seguridad de la información



Modelo AAA

El modelo AAA (Authentication, Authorization, Accounting) es un **marco de seguridad** utilizado para controlar el acceso a sistemas y recursos digitales.



Permite **verificar** la identidad de los usuarios, **definir** qué acciones pueden realizar y **registrar** sus actividades dentro del sistema.

Su implementación fortalece la seguridad y facilita la **auditoría y monitoreo** de accesos.



Importancia del **modelo** AAA en seguridad



- ✓ Permite **proteger** información sensible dentro de una organización.
- ✓ **Reduce el riesgo** de accesos no autorizados.
- ✓ Facilita el **control** y **monitoreo** de las actividades de los usuarios.
- ✓ Es fundamental para cumplir con **políticas de seguridad y normativas**.
- ✓ Se aplica en sistemas corporativos, plataformas **cloud** y redes empresariales.



Componentes del **modelo AAA**



Autenticación

Verifica la identidad del usuario.



Autorización

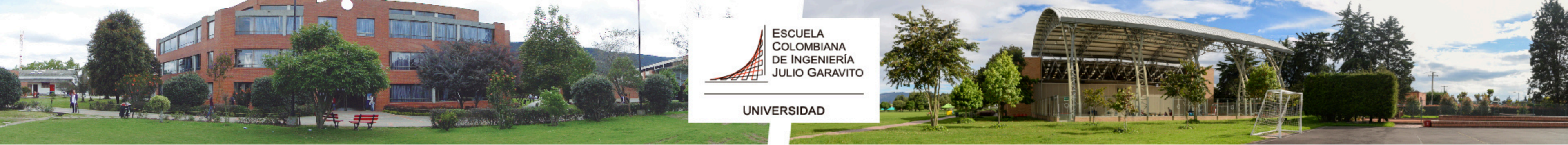
Determina qué recursos puede usar el usuario.



Contabilidad

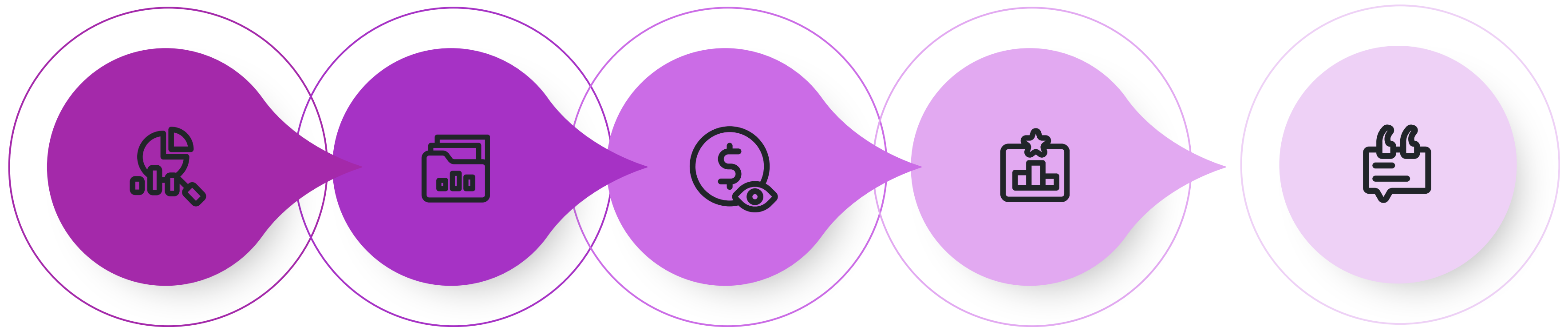
Registra las actividades realizadas por los usuarios dentro del sistema.

Estos tres elementos trabajan juntos para garantizar un **acceso seguro y controlado**.



Flujo de funcionamiento del **modelo AAA**

Proceso típico de acceso a un sistema



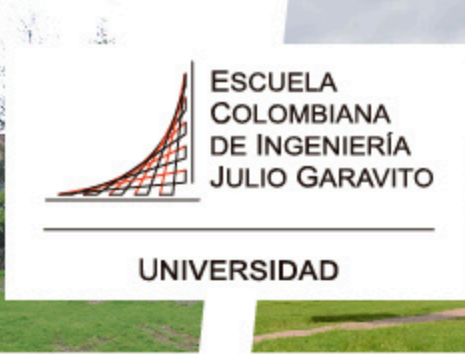
El usuario **solicita** acceso a un recurso.

El sistema realiza la **autenticación** del usuario.

Una vez verificado, el sistema **evalúa** la autorización.

Si el acceso es permitido, el usuario puede **interactuar** con el recurso.

Todas las acciones se registran mediante **accounting** o auditoría.



Gestión de **identidades** digitales

La gestión de identidades se encarga de administrar las cuentas de usuario dentro de una organización.

01 Creación de cuentas

02 Asignación de roles

03 Actualización de información

04 Eliminación de accesos
cuando el usuario ya no pertenece al sistema

Una buena **gestión de identidades** permite mantener control y trazabilidad sobre los usuarios.



Ciclo de vida de una **identidad**

Las identidades digitales tienen un ciclo de vida dentro de los sistemas:



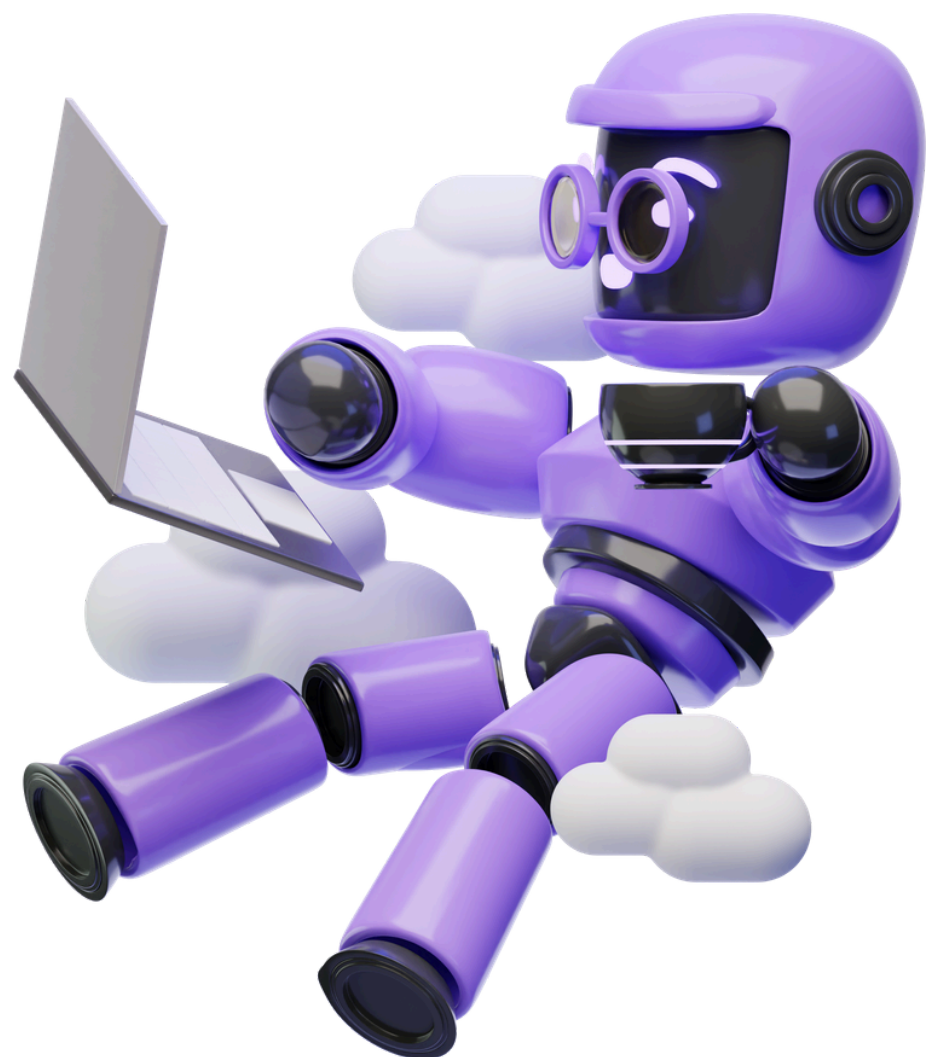
Gestionar correctamente este ciclo reduce riesgos de seguridad.



Autenticación

La autenticación es el proceso mediante el cual un sistema **verifica la identidad** de un usuario.

Se basa en tres tipos principales de factores:



01

Algo que el usuario sabe
Contraseña o PIN

02

Algo que el usuario tiene
Token, celular, tarjeta

03

Algo que el usuario es
Biometría como huella o reconocimiento facial



Métodos y riesgos de **autenticación**

MÉTODOS COMUNES DE AUTENTICACIÓN

- Contraseñas
- Autenticación biométrica
- Tokens de seguridad
- Certificados digitales

RIESGOS ASOCIADOS

- Robo de credenciales
- Ataques de phishing
- Ataques de fuerza bruta
- Reutilización de contraseñas

Por esto se recomienda implementar **mecanismos adicionales de seguridad.**



Autenticación multifactor (MFA)

La MFA (Multi-Factor Authentication) combina dos o más factores de autenticación para aumentar la seguridad.

Ejemplos

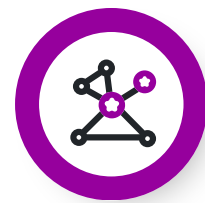
contraseña + código enviado al celular



contraseña + autenticación biométrica



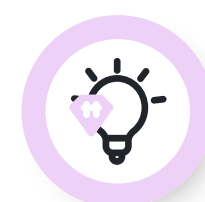
contraseña + token de seguridad



Beneficios



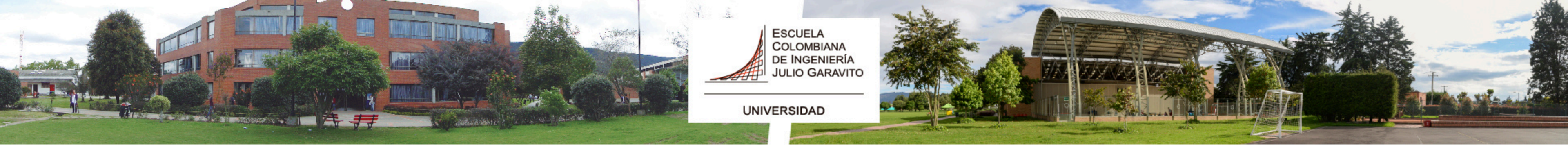
Reduce el riesgo de robo de cuentas



Mejora la protección de sistemas críticos

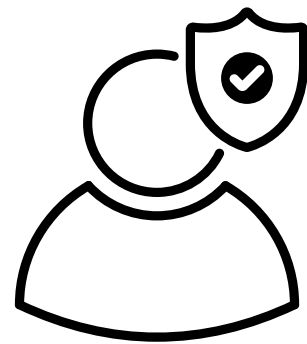


Es ampliamente utilizada en servicios financieros y corporativos.

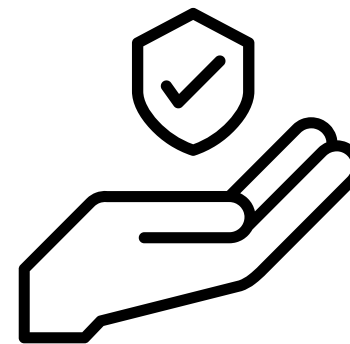


Single Sign-On (**SSO**)

El **Single Sign-On (SSO)** permite que un usuario acceda a múltiples aplicaciones utilizando **una sola autenticación**.



Mejora la experiencia del usuario

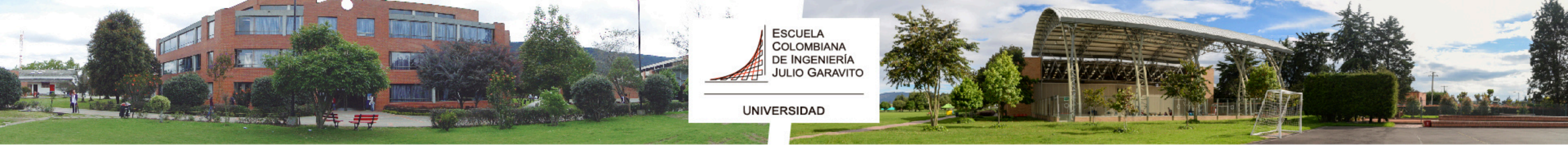


Reduce la cantidad de contraseñas



Facilita la administración de accesos

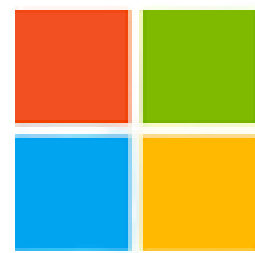
Es muy utilizado en entornos corporativos y plataformas cloud.



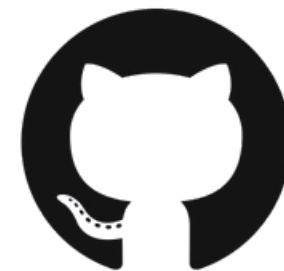
Identidades federadas

Las **identidades federadas** permiten que un usuario se autentique en un sistema utilizando credenciales de otro proveedor.

Google



Microsoft



GitHub



Este mecanismo permite **compartir identidades** entre diferentes sistemas o organizaciones.



Protocolos de **autenticación** modernos

Algunos **protocolos** utilizados para implementar autenticación y federación son:

SAML (Security Assertion Markup Language)



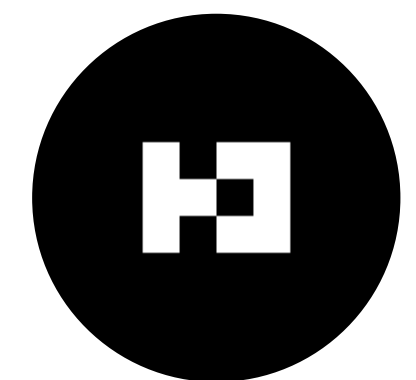
OpenID Connect



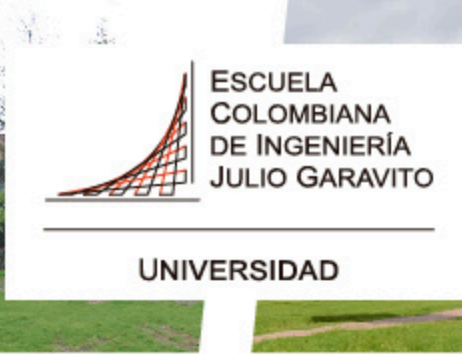
OAuth



BetterAuth



Estos protocolos permiten intercambiar información de autenticación de forma segura entre aplicaciones y servicios.



Autorización

La **autorización** determina qué acciones puede realizar un usuario dentro del sistema después de autenticarse.

Define:

- Qué recursos puede acceder
- Qué operaciones puede realizar
- Qué información puede visualizar o modificar



Es esencial para mantener **control sobre los privilegios de los usuarios**.



Principios de **control de acceso**

02

Mínimo privilegio

Cada usuario tiene solo los **permisos** necesarios.

03

Segregación de funciones

Se separan **responsabilidades** para evitar abusos.

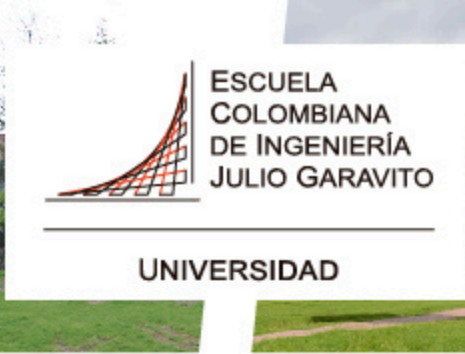
Control centralizado

Facilita la gestión de **permisos**.

04

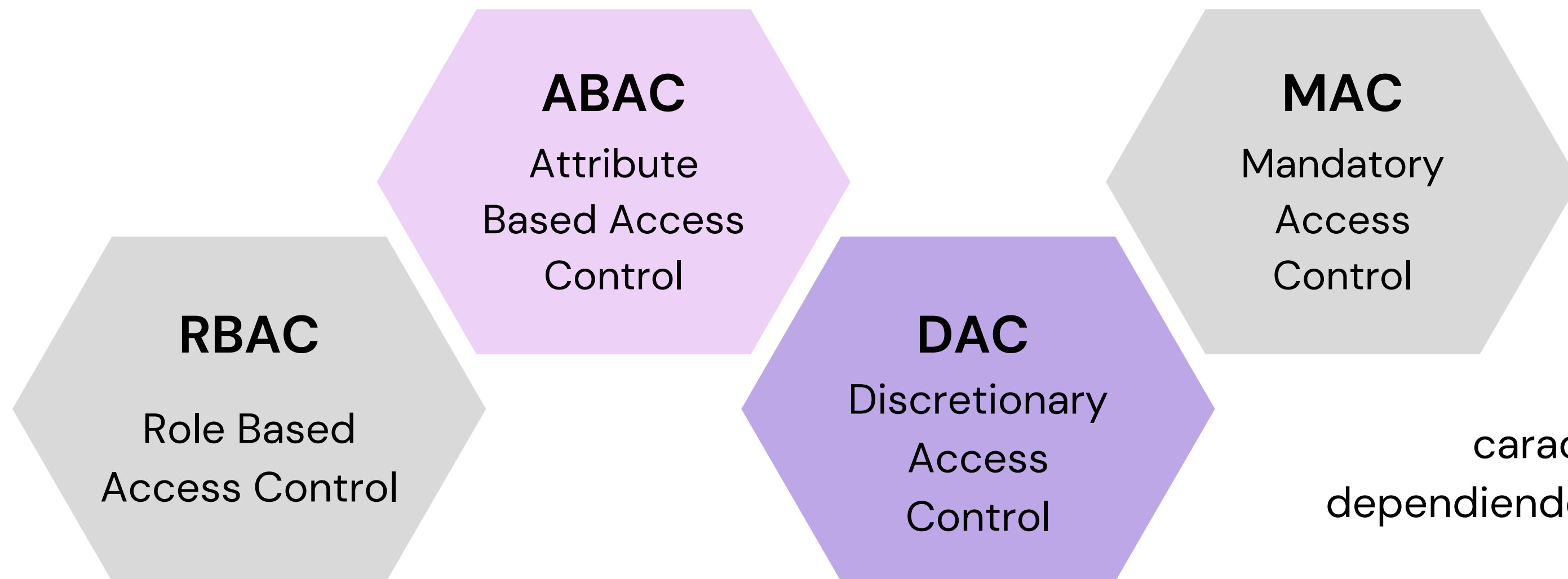


Estos principios ayudan a mejorar la **seguridad organizacional**.

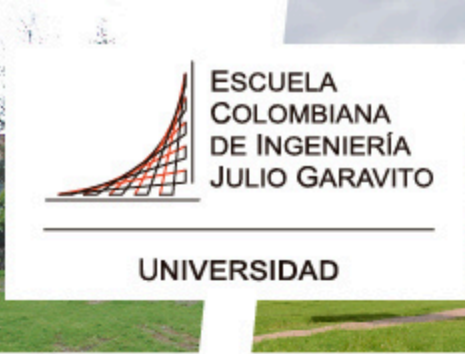


Modelos de **control de acceso**

Existen diferentes modelos que definen cómo se asignan permisos dentro de un sistema.

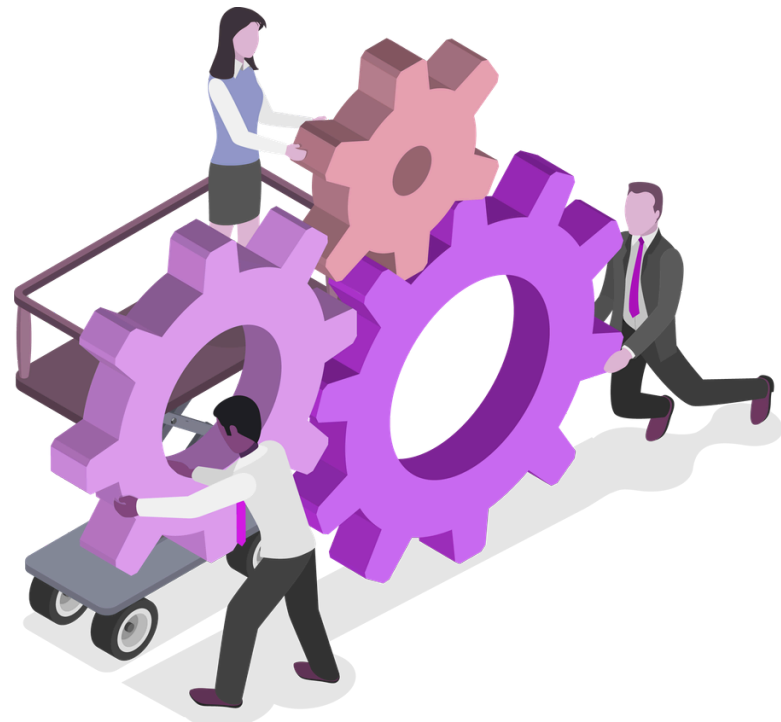


Cada modelo tiene características diferentes dependiendo del nivel de control requerido.



Control de acceso basado en roles (**RBAC**)

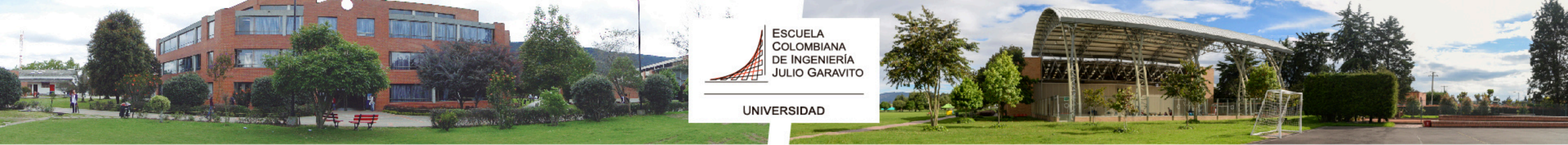
En **RBAC**, los permisos se asignan a **roles**, y los usuarios reciben **permisos** según el rol que desempeñan.



Administrador → acceso total
Empleado → acceso limitado
Invitado → acceso mínimo

Facil de
administrar

Escalable para
organizaciones grandes



Otros modelos de **control de acceso**

Cada modelo se utiliza dependiendo de las **necesidades de seguridad** del entorno.

01



ABAC

Acceso basado en atributos como ubicación, tiempo o tipo de usuario.

02



DAC

El propietario del recurso decide quién puede acceder.

03



MAC

Acceso basado en niveles de seguridad definidos por el sistema.



Accounting y auditoría

El Accounting registra todas las actividades realizadas por los **usuarios dentro del sistema**. Permite:



Monitorear
accesos



Generar evidencia
para auditorías

Detectar
comportamientos
sospechosos



Este registro es fundamental para **investigaciones** de seguridad y cumplimiento normativo.

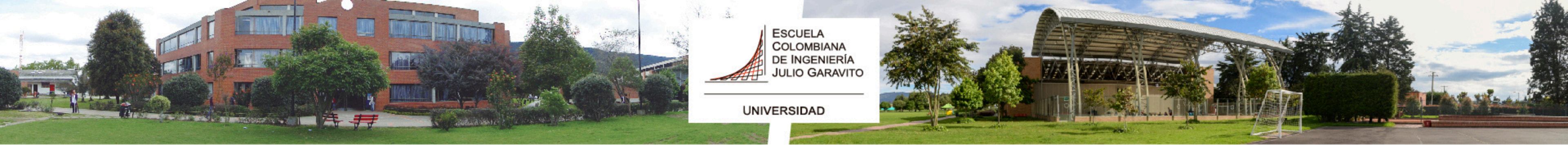


SIEM y monitoreo de seguridad

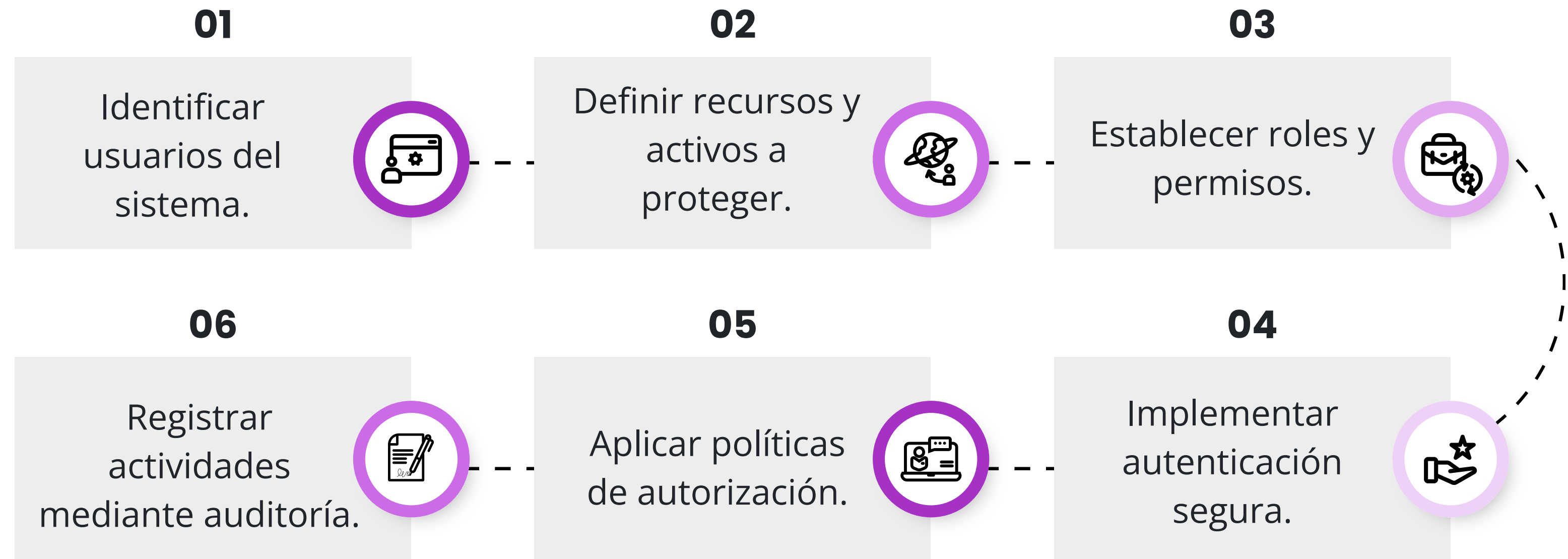
Los sistemas **SIEM** (Security Information and Event Management) **recopilan y analizan** registros de seguridad provenientes de diferentes sistemas. Funciones principales:



Permiten mejorar la **visibilidad** y respuesta ante ataques.



Diseño de un esquema de **control de acceso**



Un diseño adecuado permite garantizar **seguridad, control y trazabilidad** en los sistemas de información.

Gracias